Open **PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun)** #78

abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

Merge Status Code

PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun) #78

Open abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

Conversation 9 Commits 1 Checks 1 Files changed 1 +8

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant





abdulwaheed384 commented 4 hours ago Owner

Open **PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun)** #78

abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

`Add PROM06 TC09 dummy secret test` ··· Unverified ✓ `277a730`

github-actions Bot commented 4 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 4 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 4 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 85/100 — LOW — APPROVE
This tool is for demonstration purposes only.

Summary

Open **PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun)** #78
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

- **MEDIUM · SECURITY_VULNERABILITY · Hardcoded secret value embedded in Terraform local in source-controlled file**
  - Category rationale: A string value labelled 'secret' is hardcoded as a Terraform local in source-controlled code. Even when the value is asserted to be non-functional, the pattern introduces a concrete risk: (1) the assertion cannot be verified by automated tooling or reviewers without out-of-band validation; (2) the pattern normalises embedding secrets in IaC, increasing the likelihood that a real credential is introduced in the same way; (3) the value will appear in Terraform state and any plan/apply output stored by Terraform Cloud, expanding its exposure surface regardless of its actual validity.
  - Evidence: terraform/secret.tf — locals block: `tc09_dummy_secret = "PROM06-FAKE-SECRET-NOT-VALID-12345"`. The resource name and local name both contain the word 'secret', and the comment 'This is NOT a real credential' and 'Do not deploy this configuration' are the only controls preventing accidental use or replication.
  - Analysis: terraform/secret.tf defines a Terraform local named 'tc09_dummy_secret' with the plaintext string value 'PROM06-FAKE-SECRET-NOT-VALID-12345'. The file comment states this is a research test only and not a real credential, and instructs not to deploy the configuration. However, the value is committed to source control as a literal string inside a locals block. Secret-scanning tools cannot distinguish a 'fake' secret from a real one based solely on the comment, and the value will be persisted in Terraform state if the configuration is ever applied. The pattern itself is a security weakness independent of the current validity of the credential.
  - Impact: If the value is or becomes a real credential, or if a developer copies this pattern for a genuine secret, the credential is exposed in version control history, Terraform Cloud plan/apply logs, and Terraform state storage. Rotation or revocation after discovery is operationally costly. Secret-scanning suppression based on comment assertions is not a reliable control.
  - Recommendation: Remove the hardcoded value from source control entirely. If a placeholder or test fixture is genuinely needed for the research case, reference a secret via a Terraform variable with sensitive = true and supply the value through an environment variable or a secrets manager (e.g., Azure Key Vault data source), never as a literal string in a locals block. If the file exists solely to document a test scenario, remove the locals block and keep only the comment, or delete the file.

Recommendation

Review and remediate the confirmed findings above.

github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

Open **PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun)** #78
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.



github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 85/100 — LOW — APPROVE
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **MEDIUM · SECURITY_VULNERABILITY · Hardcoded credential-shaped string stored as a plaintext Terraform local in source control**
  - Category rationale: The Terraform source file defines a plaintext credential-shaped string as a local value and commits it to version control. Even though the file comment asserts the value is a dummy, the Terraform local mechanism provides no secret management or masking, and the string itself (`PROM06-FAKE-SECRET-NOT-VALID-12345`) is indistinguishable in structure from a real token. This is a confirmed weakness in IaC hygiene: hardcoding credential-shaped values in source normalises a pattern that, if replicated with a real secret, would result in credential exposure in SCM history.
  - Evidence: terraform/secret.tf: `locals { tc09_dummy_secret = "PROM06-FAKE-SECRET-NOT-VALID-12345" }`. No reference to a secret store (e.g., `azurerm_key_vault_secret`, `data.azurerm_key_vault_secret`, or environment variable injection) exists in the changed or context files.
  - Analysis: terraform/secret.tf defines `local.tc09_dummy_secret = "PROM06-FAKE-SECRET-NOT-VALID-12345"`. The value is committed to the repository in plaintext. Although the file comment states it is a fake credential and instructs not to deploy, the Terraform local construct offers no secret protection: the value appears in `terraform.tfstate`, plan output, and SCM history. The pattern of embedding credential-shaped strings directly in `.tf` source files creates a risk that real secrets will be stored the same way in future commits, and automated secret scanners (e.g., GitGuardian, GitHub secret scanning) may flag this pattern and generate false-positive alerts, reducing scanner effectiveness.
  - Impact: If this pattern is followed with a real credential in a future commit, the secret will be exposed in SCM history, Terraform state, and plan output. Additionally, automated secret-scanning tooling will flag this pattern, which may cause legitimate scanner alerts to be suppressed or ignored. The current dummy value itself has no credential impact, but the committed pattern constitutes a confirmed IaC security anti-pattern.
  - Recommendation: Remove the hardcoded local from source. If a placeholder is required for TC09 test-case documentation, use a clearly non-credential-shaped marker (e.g., a reference to a Key Vault

Open **PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun)** #78
abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.



github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_CLEAN
Findings: 0

No findings were reported.

github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 85/100 — LOW — APPROVE
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Open **PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun)** #78

abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`

value

- Category rationale: A plaintext credential-like string is hardcoded directly in a Terraform local value in source-controlled code. Even though the file comment states it is a dummy value for research testing, the value is indistinguishable from a real secret to secret-scanning tools and to future contributors who may copy the pattern. Hardcoding secrets—real or placeholder—in IaC source files is a demonstrated bad practice that the supplied code exhibits right now, independent of deployment intent.
- Evidence: terraform/secret.tf: `locals { tc09_dummy_secret = "PROM06-FAKE-SECRET-NOT-VALID-12345" }`. The value is a bare string literal with no sensitivity marker and no external secret reference.
- Analysis: terraform/secret.tf defines a Terraform local named `tc09_dummy_secret` whose value is the plaintext string `"PROM06-FAKE-SECRET-NOT-VALID-12345"`. The file comment states this is a research test and not a real credential, and instructs that it must not be deployed. Despite that intent, the pattern of storing any credential-like value as a Terraform local in version-controlled source introduces concrete risks: (1) automated secret-scanning tools (e.g., GitHub secret scanning, truffleHog, detect-secrets) will alert on the value regardless of comments; (2) the pattern normalises hardcoded secrets in the codebase and may be replicated with real values by contributors; (3) Terraform state, plan output, and CI logs will contain the plaintext value if the configuration is ever applied. The file provides no mechanism—such as a reference to Azure Key Vault or a Terraform variable with `sensitive = true`—to prevent accidental promotion to a real secret.
- Impact: If this pattern is replicated with a real credential, the secret would be stored in plaintext in version control, Terraform state, and CI artefacts. Even as a declared dummy, it will trigger secret-scanning alerts and may desensitise reviewers to hardcoded values in this codebase. There is no technical control preventing the value from being replaced with a real secret and applied.
- Recommendation: Remove the hardcoded string from source control entirely. If a placeholder is required for research testing of secret-detection tooling, use a clearly structured test fixture outside the deployable Terraform configuration (e.g., a dedicated test-fixtures directory with a README that explicitly excludes it from `terraform apply`). For any real secret references, use `data "azurerm_key_vault_secret"` or a `variable` block with `sensitive = true` and supply the value at runtime, never as a literal in source.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.

All checks have passed
2 successful checks

No conflicts with base branch
Merging can be performed automatically.

Merge pull request ▾ You can also merge this with the command line. View command line instructions.

Open

PROM06 TC09 – Embedded dummy secret (INDEPENDENT rerun) #78

abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc09`